

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on August 29, 2022. The complaint is directed against HM HOSPITALES 1989, S.A. with NIF A79325858 (hereinafter, HM). The reasons on which it is based are as follows:

The complainant, (...), outlines various security deficiencies related to the maintenance of a software service developed by the same and used by all hospital centers of the reported company.

According to the complainant, "Doctoris" is a complete and integrated hospital information system, composed of several databases that encompass everything from patient data to their clinical experiences, including laboratory information or even appointments at the centers for consultations. He indicates that it is not a product installed at HM, but a service whose infrastructure is hosted at the Data Processing Center of the technology company that provides services to the reported entity, where the main servers of the service are located, especially the database servers and data storage and backup systems.

He states that it is that company that must ensure the operation 24/365 of the system.

The complaint details the following alleged breaches of data protection regulations:

(...).

Along with the complaint, two email threads sent to executives of HM's technology company on 11/12/2019 and 17/5/2022 are provided.

The email dated December 11, 2019, is sent from the address ***EMAIL.1 to the recipient (...), with the following text:

(...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/45

This email is answered by ***EMAIL.2 with the following text:

“(...)”

The second email is sent on May 17, 2022 (...) and is sent from the address ***EMAIL.1 to the address ***EMAIL.3 with the following text:

“...”

SECOND: On September 19, 2022, the Director of the Spanish Agency for Data Protection, in light of the security deficiencies related to the maintenance of a software service used by all hospital centers of the company HM HOSPITALES 1989 S.A., issues an internal note, urging the General Subdirectorate of Data Inspection to initiate ex officio preliminary investigation actions aimed at verifying these facts and their authorship.

THIRD: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

The investigation actions have focused on the following control points reported as alleged breaches of data protection regulations according to documentation provided by the complainant:

(...).

On April 3, 2023, a request for information was made to the data controller HM marked by the following line of investigation:

- Analyze the data processing agreement between this controller and TRC INFORMÁTICA, S.L. (hereinafter TRC INFORMÁTICA).

- Know the risk analyses carried out by HM in relation to the processing activities affecting TRC INFORMÁTICA, as well as the accreditation of the concluded preventive measures.
- Know the impact assessments for the processing activities affecting TRC INFORMÁTICA as a processor.
- In relation to the reported hospital management system, "DOCTORIS," know:
 - ☐ The types of personal data it processes.
 - ☐ The reports of the latest audits conducted.
 - ☐ The measures implemented to ensure confidentiality, access traceability, the confidentiality of individuals who have access to the data, the deletion or blocking of data, and availability in the event of loss or destruction.
 - ☐ In relation to the pre-production and development systems, obtain clarification on whether they process real or fictitious data, and the measures for

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/45

to guarantee the confidentiality of users who have access to the system.

On April 26, 2023, a response to the previous request was received from HM, from which the following is extracted:

- A copy of the service contract signed between HM and TRC INFORMÁTICA is provided, from which the following is extracted:
 - ☐ It is dated January 1, 2022, and contains the signatures of both parties who signed it.
 - ☐ Regarding the object, nature, and purpose of the service: "the services provided are the software development of electronic medical records and billing management, software maintenance, and database hosting, requiring the processing of personal data for these services."
 - ☐ It is stated: "That in compliance with Article 28 of the GDPR, the processor offers sufficient guarantees to implement appropriate measures to protect the rights of the data subjects, and therefore both parties have agreed to sign the contract."
 - ☐ The types of data affected by the service, the types of affected data subjects, and the obligations and rights of both the controller and the processor are detailed.
 - ☐ Information about the notification of security breaches, the communication of data to third parties by the processor, international transfers, the possibility of subcontracting, and the attention to the rights of the data subjects is detailed.
 - ☐ Regarding the authorized personnel to carry out the processing, the following is specified:
 - ☐ The processor guarantees that the authorized personnel to carry out the processing have expressly and in writing committed to respecting the confidentiality of the data.
 - ☐ The processor will take measures so that this personnel can only process the data following the instructions of the controller.
 - ☐ The processor guarantees that the authorized personnel for processing have received the necessary training to ensure that the protection of personal data is not compromised.
 - ☐ Regarding the security measures implemented, an annex to the service contract is attached where it is stated: "The development of the DOCTORIS software must include the following security measures in its design and by default:

(...)

- ☐ The contract includes contact information for both DPOs and information about the obligations for the deletion and return of data after the contracted service has ended.
- The Record of Processing Activities (RAT) of HM is provided, and it is stated that the activities affected by data processing in which TRC INFORMÁTICA acts as a processor are two: the activity "Billing" and the activity "Electronic Medical Record (EMR)." The provided RAT details the following information for each of these activities: Purpose, Legitimacy, Categories of Data Subjects, Retention Criteria, Source of Data, Categories of Data, Categories of Recipients, and Security Measures.
 - ☐ For the EMR activity, the following information contained in the RAT is highlighted:

☐ Data: ID number or tax identification number, name and surname of the patient, health card, user identifier, images, recordings, electronic signature, handwritten signature, personal characteristics (personality or behavior), social circumstances, academic and professional details, employment details.

☐ Special categories of data: Ethnic or racial origin, genetic data, health, gender-based violence, religion.

☐ Data retention periods: "As long as the healthcare attention to the patient lasts and subsequently, for a minimum of 5 years counted from the date of discharge of each care process, without prejudice to the autonomous particularities that may apply, or the nature of some documents that will be part of the EMR, requiring their indefinite retention (detailed in HM HOSPITALS' Protocol on retention periods, health regulations)."

☐ Security measures:

(...)

☐ For the BILLING activity, the following information contained in the RAT is highlighted:

☐ Data: ID number or tax identification number, name and surname of the patient and payer, billing postal or electronic address, user identifier.

☐ Special categories of data: Health data related to the provision of healthcare subject to billing (EMR).

☐ Retention period: "The data will be maintained for the time necessary to fulfill the purpose for which it was collected and subsequently to determine any possible liabilities that may arise from that purpose and from the processing of the data. In accordance with Article 25 of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism, they will be retained for 10 years from the termination of the business relationship or the execution of the operation."

☐ Security measures:

(...)

- In response to the request to provide the risk analyses of the processing activities in which the processor TRC INFORMÁTICA is involved, they only provide a risk analysis document for the "fiscal and accounting" treatments and state that these include the processing of the "Billing" activity; no risk analysis is provided for the EMR processing activity. From this document, the following is extracted:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/45

- The following statement of dates is made:

- "Start date of treatment: already initiated previously, but updated on March 31, 2023, with the latest implementation of DOCTORIS.

- Date of report drafting: 31/03/2023"

- The analysis includes a copy of a compliance report conducted for the billing treatment activity, highlighting the following statement made in the conclusions section of the report:

(...)

- Risk factors are analyzed:

(...)

- An inherent risk assessment of MEDIUM and residual risk of MEDIUM is concluded.

- An action plan is provided that includes:

(...)

- In response to the request to provide the Impact Assessment (EIPD) for the treatments involving the processor TRC INFORMÁTICA, only a document with the EIPD for the treatment activity HCE "Electronic Medical Record" is provided, with no EIPD for the treatment activity "Billing." From the analysis of this document, the following is extracted:

- The following statement of dates is made:

- "Start date of treatment: 31-03-2023 (first phase of implementation completed for DOCTORIS, although the treatment had already started through HOSMA previously)

- Date of EIPD report completion: 15-03-2023. Version: 3."
- It is stated: "Large-scale processing of special categories of personal data. Processing that entails a high risk to the rights and freedoms of natural persons."
- This EIPD includes a copy of an internal compliance report conducted for the HCE treatment activity, containing the following statements in the conclusions section:

(...)

- A description of the treatment and the data lifecycle is provided, analyzing each of the following processing operations: capture, registration, use, communication, and deletion. For each operation, the type of data processed, the source of the data, the security measures implemented, and the technologies involved are specified.

- The following risk factors are identified and evaluated:

(...)

- The following controls are provided to reduce the risk:
- Establish awareness and training measures for personnel involved in personal data processing operations.
- Establish technical means for the automatic detection of personal data breaches.
- It concludes with inherent risk of MEDIUM and total residual risk of MEDIUM.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/45

- It is stated that the following risks are transferred to TRC INFORMÁTICA SL:

(...)

- It concludes with an action plan that includes the following controls:
- Controls to reduce the risk of regulatory non-compliance:

(...)

- Controls to reduce risks to the rights and freedoms of data subjects:

(...)

- Controls aimed at transferring the risk:

(...)

- The necessity and proportionality of the treatment are analyzed, reaching the following conclusion: "The assessment of the necessity and proportionality of the treatment concerning its purpose is adequate, and risk management can proceed."

- The following conclusions from the EIPD are provided:

(...)

- In response to the request to provide the latest specific audit conducted for the DOCTORIS hospital information system, the response is: "HM HOSPITALES has not conducted an audit of the DOCTORIS information system as its implementation in the hospital group is recent."

- In response to the request to provide the technical measures implemented to ensure the confidentiality of the treatments, they respond:

(...)

- In response to the request to certify the measures to ensure the traceability of accesses:

(...)

- In response to the request to certify the measures to ensure availability in the event of possible loss, destruction, or accidental damage:

(...)

- In response to the request to certify the measures to ensure deletion or blocking once the retention period has ended:

(...) However, there is evidence that DOCTORIS is not new software, but rather likely an evolution of an existing one (HOSMA) and that both support the same treatment activity HCE (Electronic Medical Record).

- Regarding the pre-production or development systems of DOCTORIS, it is stated:
- That tests related to the implementation or modification of DOCTORIS will not be conducted with real data.
- That access profiles to HM data are managed by authorized developers. A list with the names of these authorized individuals is provided, and it is stated that there are "various developers" who access Pre-production, but with denormalized data.
- A document certifying ISO 27001:2017 certification by the data processor, TRC INFORMÁTICA SL, is provided.

In relation to the processing of the Electronic Medical Record (HCE) by HM HOSPITALES and the processor TRC INFORMÁTICA, the following evidence of news published on portals is collected during this investigation:

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 7/45

Relevant information from the internet regarding the implementation of the information system that supports the Electronic Medical Record:

- News published by the TRC INFORMÁTICA website about the development project of the Hospital Management application Doctoris for the client HM HOSPITALES, with the project date ranging from 2010 to the present.
- News published on various health websites in 2011 with the headline "HM Hospitales has implemented the electronic medical record in all its centers," stating that HM has completed the implementation of the Electronic Medical Record in all its centers under a single system known as HOSMA DR, and that it aimed to advance the development of new applications to improve its functionality.
- News published on the computing.es website in 2013 about the technological revolution at HM Hospitales, announcing the new implementation of HOSMA 2.0 as an evolution of the Electronic Medical Record carried out by HM in collaboration with TRC INFORMÁTICA.

On May 30, 2023, it was decided to request information from the complainant, marked by the following line of investigation:

- Contrast the information provided by HM.
- Request the submission of contrary evidence in relation to (...).

On June 7, 2023, a response to the previous request was received, from which the following considerations can be drawn:

- It states that "HOSMA 1.0, HOSMA 2.0, and DOCTORIS are not at all three different systems, but rather evolutions of the frontends of the same system, with different technologies according to the time and with functionalities both different and overlapping."
- Regarding audits, it states that for years the company KPMG has conducted audits of the complete system (formerly HOSMA and now DOCTORIS), but that there is no exclusive audit for the DOCTORIS system, as it is merely an evolution of the frontend of the complete hospital information system.
- (...).

On May 31, 2023, it was decided to make a new information request to HM marked by the following line of investigation:

- To prove the existence of a protocol for managing security breaches, as stated in response to the first request.
- To prove the existence of an Impact Assessment dated prior to the one provided (March 15, 2023), as the start of processing is considerably earlier than this date.
- Request a copy of the latest audit report conducted by KPMG, as included in the action plan of the Impact Assessment provided to us.
- (...).
- To prove that the pre-production systems handled fictitious data and not real data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/45

On June 12, 2023, a response to the previous request was received, from its analysis the following is extracted:

- The document is signed by the Data Protection Officer of HM (D. B.B.B.).
- A protocol for managing security breaches is attached and accredited, a document created in December 2020 that outlines aspects for identifying, classifying, and assessing the dimension and scope of possible security incidents that the organization may suffer, as well as establishing an internal action plan for prevention, mitigation, and compliance.
- In response to our request for the Impact Assessment (EIPD) conducted prior to the start of processing, a new EIPD document for the EMR activity is provided, from which the following is extracted:
 - The document is not signed and has a creation date of December 16, 2020.
 - It includes the analysis of the need to carry out the EIPD.
 - It states that an inherent risk analysis has been conducted and that it is provided in an additional document attached along with the action plan; however, these additional documents cannot be located.
 - It states that "Once the potential risks are evaluated, it is concluded that the processing does not pose a threat to the rights and freedoms of patients."
 - The EIPD does not conduct an analysis of the necessity, appropriateness, and proportionality of the processing.
 - The EIPD does not carry out a systematic description of the processing.
- In response to our request for confirmation and accreditation of the audit of the clinical information system by KPMG, a document titled "Comprehensive Legal Report on the Risks and Legal Impact Associated with a Cyber Incident, Including Recommendations and Best Practices," dated September 12, 2022, is provided.
- Regarding our request to accredit (...).
- Regarding the accreditation of the use of fictitious data by the pre-production systems, they state: "It is reported that the tests conducted take place in a PRE-PRODUCTION environment in which situations are simulated with fictitious databases generated using techniques such as noise simulation and data perturbation." A screenshot of DOCTORIS is provided with a very small sample of 12 records of supposed fictitious patients.

On May 31, 2023, it was decided to make a new information request to the processor TRC INFORMÁTICA marked by the following line of investigation:

- Request a copy of the report of the last audit conducted by KPMG.
- Request the record of processing activities as a processor.
- Request accreditation of the measures implemented to ensure traceability of access to medical records.
- Request accreditation of the established procedures for the deletion and blocking of data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/45

On June 13, 2023, a written request was received from TRC INFORMÁTICA requesting an extension of the deadline, which was favorably responded to on June 14, 2023, granting an additional 5-day period.

On July 3, 2023, a response to the previous request was received from TRC INFORMÁTICA, from which the following is extracted:

- In response to our request for them to provide a copy of the audit reports conducted by KPMG on the hospital information management systems, they state: "KPMG is the auditing company for our client HM HOSPITALES 1989 S.A. and is not the auditing company TRC INFORMÁTICA; consequently, we cannot provide the copies of the requested reports."

- Regarding the list and accreditation of the measures implemented to ensure the traceability of access to the Electronic Medical Records, the same measures previously accredited in the response from HM HOSPITALES are confirmed, specifically:

☐ The registration of access attempts to the Doctoris system is accredited.

☐ The registration of the different modules of the system visited by the user (program options) is accredited.

☐ The registration of queries launched to the database directly without using DOCTORIS is accredited.

☐ The registration of changes made in the patients table is accredited.

- (...).

- In relation to our request for them to accredit the measures for blocking or deletion, they state: (...).

- They assert (although they do not provide evidence) that TRC INFORMÁTICA is certified by OCA GLOBAL under the ISO/IEC 15504, ISO/IEC 33001 standards. Previously, certification under the ISO/IEC 27001 standard had already been accredited.

On June 14, 2023, it was decided to make a new information request to the data controller HM, requesting clarification on some aspects of their previous response, specifically requesting:

- To confirm the relationship between the DOCTORIS, HOSMA1, and HOSMA 2 systems, in order to clarify whether they are systems that support the same HCE processing activity.

- Considering that the contract provided between TRC INFORMÁTICA and HM is dated January 1, 2022, and from the evidence obtained from the internet regarding the start of this development project being dated much earlier, it is requested that they confirm (and provide evidence if applicable) the existence of a service contract dated prior to the one provided.

- To confirm and provide a list of possible service contracts with the public sector related to the hospital information system.

- To confirm whether there were specific audits for any of the HOSMA or DOCTORIS systems in the last three years in order to verify the measures implemented and assess their effectiveness.

On June 21, 2023, a written response was received from HM providing answers to the first two points of the information request and requesting an extension of the deadline to respond to the remaining points. A favorable response was given, granting an additional 5-day period. Regarding the two points answered, the following is extracted:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/45

-

In response to our request for confirmation of whether there was a signed service contract dated prior to January 1, 2022, a new document is provided with a new service contract signed on June 1, 2019, with the following characteristics:

☐

It is signed on one side by PROFESIONALES DE LA MEDICINA Y LA EMPRESA S.A with CIF A79272118 and on the other side by GRUPO TRC composed of the companies TRC INFORMÁTICA SL (B7951315) and GRUPALIA INTERNET SA (A47436019).

☐

It is stated that the responsible party has contracted the services of the service provider, the purpose of which is detailed in the second statement; however, these annexes (statements) are not provided, making it unclear what the object of the service is and it cannot be verified that the service is related to the electronic medical records system of patients.

☐

The contract specifies the following types of affected data: basic data, data of special protection (religious and philosophical beliefs, convictions and criminal offenses, ethnic or racial origin, sexual life or orientation, gender-based violence), data that identify personal characteristics, academic and professional details, employment, economic, financial, and insurance details, administrative infringements, biometric, health, and genetic data.

On June 28, 2023, a response to the previous request is received from HM, from which the following is extracted:

-

It is confirmed that both "HOSMA 1.0" and "HOSMA 2.0" are versions prior to DOCTORIS, the hospital information system used by HM for the management of electronic medical records (EMR).

-

The following statement is made: "In relation to the performance of audits on any of the versions of Doctoris in the last three years, this party informs that none have taken place. Due to the COVID-19 pandemic situation, HM Hospitals has been forced to redirect its resources and priorities mainly towards healthcare and the safety of patients and staff. Once the health emergency situation has been overcome, the HM HOSPITALS Privacy Committee approved in April 2023 the conduct of audits in various centers to verify the level of compliance with current data protection regulations for all information systems in the second half of this year."

-

A list of public sector tenders obtained by HM in the last two years is provided, highlighting among others the following:

☐

With SESCOAM, in 2022, regarding "Healthcare for patients."

☐

With the Madrid Health Service, in 2022, regarding "Diagnostic tests."

☐

With INGESA, in 2022 and 2023, regarding "Preventive medical examinations for public employees."

-

They state that HM is currently in the process of implementing the ENS, a project that began with its first phase in April 2023 and will continue with the following planning:

☐

In July 2023, the phase of "Inventory of assets, risk analysis, and selection of controls" will be carried out.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/45

- August and September 2023 will involve the preparation or expansion of the defined scope documentation.

- October - December 2023 will include phases of system implementation, internal audit, and certification process.

FOURTH: On August 29, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

FIFTH: After notifying the aforementioned initiation agreement in accordance with the rules established in the LPACAP, the accused party submitted a written request for an extension of the deadline granted to formulate allegations, as well as a copy of the file. On September 13, 2023, the granted extension was agreed upon, which should be computed from the day following the receipt of the requested file copy. The copy of the file was notified on October 2, 2023.

However, HM submitted allegations on September 14, 2023, requesting that they be admitted and considered in the resolution of the referenced procedure, and consequently, that the proposed sanction be annulled or reduced due to the absence of the requirements for its imposition.

In their allegations, in summary, the accused party argues:

1.- In their first allegation, HM refers to traceability, stating that they demonstrated the technical and organizational security measures implemented to ensure the traceability of access to personal data by authorized users in their first response to the information request by the AEPD, dated April 27, 2023. However, they subsequently acknowledge that, in the impact assessment provided on the same date and conducted on March 15, 2023, it was detected that DOCTORIS did not allow recording which specific HCE each user had accessed unless they had modified the records. They also claim to have rectified this issue by providing screenshots of the tests they have conducted to prove it.

2.- In their second allegation, they refer to the existence of internal reports from the responsible party of HM regarding compliance with regulations concerning these activities (Annexes No. 1 and No. 2 attached to the allegations), highlighting a series of points that are included in the conclusions of these reports from 2023 and are detailed as follows:

- It is detected that the profiles are not well implemented (nursing, researchers): in this regard, they clarify that they have identified a risk that they consider resolved at present, which originated from the granting of an incorrect research profile; since some of the individuals to whom it had been granted were not researchers but nursing staff.

Detail: C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/45

that, to resolve it, they adopt in 2023 a series of measures such as the limitation of the number of users who can manage, modify, and create profiles in DOCTORIS.

- It is detected that DOCTORIS allows for the traceability of accesses and modifications, but does not allow knowing who consults the HCE data. In this regard, they limit themselves to stating that it has already been explained in their first allegation.

- LOGS access retention, in addition, retains who performs the activity, when it is performed, and on what information, regardless of the user. Review of the same on a monthly basis: they proceed to detail the periods during which they retain the records and the reasons for doing so, highlighting that once the times are determined, automatic deletion of the same has been scheduled, which was previously done manually.

3.- In their third allegation, the responding party refers to audits to confirm that no specific audit of the DOCTORIS software has been conducted in the last three years, justifying this by the constant change/improvement to which the program is subjected. They add that what has been done during this period is to carry out two impact assessments, which they claim were previously submitted to this Agency.

Subsequently, they move on to the performance of audits as security measures for the HCE activity reflected in the Record of Processing Activities, to assert that audits have indeed been conducted. In particular, they indicate that compliance audits related to the processing of HCE have been carried out and that DOCTORIS has been subject to verification through a system homologation procedure for electronic prescriptions, within which it is certified that the system has an adequate level of compliance.

4.- Next, they refer to the encryption of data to assert that the database of patient medical histories in DOCTORIS has always had a personal data encryption system that has been improved several times. They continue explaining that this system had, by default, automatic encryption and that it has been enhanced. They proceed to explain how these improvements have been implemented and conclude by stating that the process of implementing encryption with TDE technology from SQL Server has now been completed, including in their writing a series of screenshots of the system.

5.- In their fifth allegation, the responding party again refers to conclusions drawn from their internal

reports. In particular, they analyze the following aspects:

- Personal data is retained for longer than necessary concerning the purposes, without these purposes being for public interest archiving, scientific research, historical, or statistical purposes.

They begin their explanation by acknowledging that it was in the DPIA conducted in March 2023 where the risk of retaining data longer than necessary according to the purpose of processing was detected.

However, they argue that, due to the nature and extent of the centers they have, distributed throughout the national territory, various regulatory provisions must be taken into account, varying the times according to the criteria that must be...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/45

apply to each reference center citing various regional examples in which different retention periods are established, ultimately stating that they have set a uniform criterion for all of them.

- The process takes place manually and there is a need to automate processes in order to comply with the HM HOSPITALES Retention Period Protocol: they consider that the intervention of a healthcare professional is necessary to determine whether or not the deletion of clinical history data is appropriate, referring to their Technical Instructions and Improvement of Records in Dharma (Annex No. 3) for clarification.

- It has been detected that DOCTORIS does not allow for automatic deletion/blocking and must be done manually. Doctoris does not have an automated process for blocking and deleting personal data, so it must be done manually, which poses a risk of non-compliance regarding the principle of limitation of retention periods: in this regard, they emphasize again that a mechanism has been implemented that allows for the blocking of health data in DOCTORIS as well as the automatic deletion of the same once the established time period has elapsed.

6.- They conclude their presentation by referring to the application in the procedure of the aggravating factor of Intentionality or negligence, as they believe that this does not apply. They base the inapplicability of the same on the following aspects:

- a) The investigations by the AEPD originated from a complaint by a former employee, not from the occurrence of a security incident or a patient's claim;

- b) They are aware of the importance of large-scale health data processing, and proof of this is the performance of two impact assessments on their part, those referred to previously from December 2020 and March 2023, whose purpose is to evaluate and minimize the possible risks that may affect the privacy and security of patient data;

- c) They believe they have demonstrated that the clinical history management system has security measures and IT security protocols to prevent unauthorized access. In addition, they add that they have carried out awareness and training actions for their staff to reinforce the culture of privacy and the proper handling of sensitive information;

- d) They highlight the fact that they are currently in the process of implementing the National Security Scheme (ENS)

- e) Finally, they refer to their full cooperation with the administration throughout the investigation.

Along with these allegations, HM attached the following documentation:

ANNEX No. 1: Analysis report on the need for EIDP of the processing.

ANNEX No. 2: Final report on the assessment of compliance with the procedure for the homologation of the electronic private medical prescription system.

ANNEX No. 3: Technical instructions and improvement of the records in DHARMA.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/45

SIXTH: On September 30, 2023, an extension of the complaint filed by Mr. A.A.A. on August 29, 2022, was received by this Spanish Agency for Data Protection.

In this extension of the complaint, it is stated that (...).

SEVENTH: On April 8, 2024, the opening of the evidentiary period was notified, and HM was requested for the following documentation and information:

Report on the results of the audits carried out in the different centers to verify the level of compliance with the current data protection regulations of all information systems in the second half of 2023, in accordance with the SEMESTRAL AUDIT PLAN OF THE PRIVACY MANAGEMENT SYSTEM (SGP).

EIGHTH: Following the notification of the opening of the evidentiary period, on April 26, 2024, the entity submitted a document stating that it had conducted the audit of its centers located in Málaga and had postponed that of the Arganda center to the second half of this year in accordance with its semiannual audit plan, without referring to the rest of its centers. It also attached the following documentation:

ANNEX No. 1: Results of the Audit carried out in the Málaga centers.

ANNEX No. 2: Registration of the Data Protection Officer with the Spanish Agency for Data Protection, of Desarrollos Asistenciales Sur, S.L.

ANNEX No. 3: Registration as Data Protection Officer of HM HOSPITALES 1989 S.A.

NINTH: On June 11, 2024, a resolution proposal was made, proposing to sanction HM HOSPITALES 1989, S.A., with NIF A79325858, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of €200,000 (TWO HUNDRED THOUSAND EUROS).

TENTH: Following the notification of the resolution proposal in accordance with the rules established in the LPACAP, the accused party submitted a document with allegations on June 26, 2024.

In their allegations, in summary, the accused party states:

1.- In their first allegation, HM refers to data encryption and indicates that the instructor of the file implies that HM Hospitals considers that encryption in the cabinet is not sufficient and that is why they planned encryption by SQL software DES, proceeding to indicate the crucial aspects of their commitment to data security as well as the balance of providing healthcare and ensuring the availability of data. They believe that the encryption previously used by HM HOSPITALES already provided a level of security that exceeded the minimum, proceeding to describe the encryption standards they used, the fact that the encryption was performed at the firmware level, and the advantages of the self-encrypting drives used.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/45

2.- In its second allegation, HM refers to the reports from various audits:

(...).

This last report mentions the areas for improvement in IT of the software DOCTORIS.

3.- In its third allegation, HM claims due diligence in the selection of the data processor, ensuring the application of appropriate technical and organizational measures, noting the certificates held by said data processor.

4.- In the fourth allegation, HM refers to each of the points on which it considers that this Agency has based the lack of adequate technical and organizational measures for the processing:

- The encryption system.
- The use of fictitious data in pre-production and development testing environments.
- The lack of traceability of access to the hospital management system by users accessing medical records.
- The performance of audits.
- The profiles of the users.

It concludes that it has demonstrated the degree of compliance (in whole or in part) of each of these aspects with the documentation provided during the procedure.

5.- In the fifth allegation, HM refers to the principle of proportionality, established in Article 29 of Law

40/2015 on the Public Sector Regime regarding the imposition of sanctions by the Administrations, and specifically considers the following criteria:

- Degree of culpability or intent.
- Continuity or persistence in the infringing conduct.
- Nature of the harm caused.
- Recidivism.

All of the above leads it to conclude that the procedure should be annulled or, failing that, the amount of the proposed sanction should be reduced, as it believes that the requirements for its imposition are not met.

Along with these allegations, HM attached the following documentation:

ANNEX No. 1: Document on technical characteristics guaranteed by the provider Fujitsu as well as a certificate from TRC INFORMÁTICA regarding encryption.

ANNEX No. 2: KPMG Audit Report.

ANNEX No. 3: List of certifications granted to TRC INFORMÁTICA.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/45

FIRST: It has been established, as stated in the file and on its own website ^{***URL.1}, that HM HOSPITALES 1989, S.A. with NIF A79325858 and address at Plaza Conde Valle De Suchil, 2 - 28015 Madrid, is a private hospital group that provides services nationwide with 49 centers distributed throughout Spanish territory, particularly in the Community of Madrid, Galicia, Castilla y León, Castilla-La Mancha, Catalonia, and Andalusia.

SECOND: It is recorded in the file, through a document submitted by Mr. A.A.A. on June 6, 2023, the following link ^{***URL.2}, which allows access to the publication of the registration as a trademark of the application “Doctoris” on November 16, 2017, requested by TRC INFORMÁTICA S.L.

THIRD: It is proven in the file, through a document submitted by Mr. A.A.A. in the context of the investigative actions carried out, that “Doctoris” is the hospital management software used by HM HOSPITALES 1989, S.A.

It is recorded in the file that the software application “Doctoris” is an evolution of Hosma (Hosma 1.0 and Hosma 2.0).

Hosma 1.0 was implemented around 2008.

The operational launch of Hosma 2.0 was around 2013.

Hosma 3.0 did not exist, and Hosma 4.0 is “Doctoris.”

FOURTH: It is established in the file, specifically in the compliance report attached to the Risk Analysis related to data protection dated March 31, 2023, that the data processing carried out by HM HOSPITALES 1989, S.A. concerns the following categories of data:

- “Basic data: Personal data that do not correspond to special categories of data or to criminal convictions and offenses, for example: name, address, email, phone, age, sex, signature, image, hobbies, assets, banking data, academic, professional, social, commercial, financial information, etc.
- Special categories of data: Data relating to ethnic or racial origin, political opinions, religious or philosophical beliefs, trade union membership, genetic or biometric data that allow for the unique identification of a person, data relating to health or sexual life and orientation.”

FIFTH: It is recorded in the file that such processing, as stated in the Report on the necessity of a Personal Data Impact Assessment, submitted by HM HOSPITALES on September 14, 2023, is on a large scale.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es

17/45

SIXTH: It is recorded in the file, the data processor contract submitted by HM HOSPITALES 1989, S.A. on April 26, 2023, signed between it, as the data controller, and TRC INFORMÁTICA, S.L., as the data processor, on January 1, 2022, with the following information:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es

18/45

SEVENTH: It is proven in the file, through a document submitted by HM HOSPITALES on June 28, 2023, references to the following contracts signed between HM HOSPITALES and the public sector for the provision of healthcare services, since the year 2022:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es

19/45

EIGHTH:

It is recorded in the file the Compliance Report corresponding to the Risk Analysis related to Data Protection carried out on March 31, 2023, under the coordination of Ms. C.C.C.

In the Billing Processing, Registration of tax and accounting obligations subject to economic activity, the following information is noted:

NINTH: The file contains the following impact assessments related to data protection:

IMPACT ASSESSMENT RELATED TO DATA PROTECTION ELECTRONIC MEDICAL RECORD dated December 16, 2020.

IMPACT ASSESSMENT RELATED TO DATA PROTECTION dated March 15, 2023.

TENTH: The file contains the Impact Assessment Report related to Data Protection HM HOSPITALES 1989, S.A., dated March 15, 2023, and under the responsibility of Mr. D.D.D., data protection delegate. To this Impact Assessment, a Compliance Report is attached, which states literally:

ELEVENTH: According to documentation provided by HM HOSPITALES on September 14, 2023, it is considered accredited that the deficiency presented by its medical records management system regarding the traceability of login attempts in the system and users who have accessed, the access activity to the different modules, including which medical record has been accessed, as well as the type of information or part of the medical record that has been consulted, has been remedied after being verified in the impact assessment conducted in March 2023.

TWELFTH: It is recorded in the file, in the allegations to the initiation agreement presented by HM HOSPITALES on September 14, 2023, the following statement regarding the limitation made in its last review concerning the number of users who can access the management system "Doctoris": "... the number of users with permissions to create and modify profiles, so that currently there are only 12 users who can administer, modify, and create profiles in Doctoris with the aim of having a more reinforced control over the creation and assignment of profiles...".

THIRTEENTH: It is recorded in the file, in the allegations to the initiation agreement presented by HM HOSPITALES on September 14, 2023, documented evidence that it has proceeded to program a mechanism that allows blocking health data in "Doctoris", to prevent its processing, including its visualization, when appropriate.

This mechanism establishes a time frame and once exceeded, the automatic deletion of the blocked data will proceed.

FOURTEENTH: It is recorded in the file that HM HOSPITALES had automatic encryption in the disk storage systems and that the process of implementing encryption of databases at rest using SQL Server TDE technology has now been completed.

FIFTEENTH: It is recorded in the file, Semiannual Audit Plan dated May 27, 2023, SEMIANNUAL AUDIT PLAN, in which it states literally:

"... the need to carry out an audit in the centers located in Málaga that were incorporated into the group in 2022 was recognized, in order to verify the adoption of the processes established by the Organization, particularly those related to the Privacy Management System (SGP) of the centers of Desarrollos Asistenciales Sur, S.L.

The hospital centers involved in this audit are:

- Hospital HM Málaga.
- Hospital HM Gálvez.
- HM Santa Elena.
- HM El Pilar.

The main purpose of this audit is to ensure that the hospital centers maintain the high level of compliance required by HM Hospitales by applying the established internal policies and procedures to guarantee the privacy and security of patient and medical staff information. Through a thorough review, it seeks to identify non-compliance and areas for improvement in the management of personal data privacy in these centers..." (the underlining is from this AEPD).

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/45

digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure. Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Unfulfilled Obligation

Article 4 of the GDPR specifies what is to be understood by the data controller and the data processor. Thus, we have:

"7) 'data controller' or 'controller' means the natural or legal person, public authority, service, or other body which, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be laid down by the law of the Union or of the Member States;

8) 'data processor' or 'processor' means the natural or legal person, public authority, service, or other body which processes personal data on behalf of the controller..."

In this case, HM carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of the aforementioned Article 4.7 of the GDPR.

On the other hand, TRC carries out this activity in its capacity as the data processor, as it processes personal data on behalf of the data controller, in accordance with the aforementioned Article 4.8 of the GDPR.

In summary, the data controller is the natural or legal person or public authority that decides on the

processing of personal data, determining the purposes and means of such processing.

By virtue of the principle of proactive responsibility, the data controller must implement technical and organizational security measures to comply with and be able to demonstrate compliance, taking into account the risk involved in the processing of personal data.

For its part, the data processor is the natural or legal person, public authority, service, or other body that provides a service to the controller that involves the processing of personal data on behalf of the latter.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/45

In this regard, the controller is the one who decides the "why" and the "how" concerning personal data, while the processor is the one who carries out the processing on behalf of the controller.

The role of the processor under the GDPR is defined in Article 28, which sets out the requirements that must be met regarding data protection:

1. When processing is to be carried out on behalf of a controller, the controller shall only choose a processor that provides sufficient guarantees to implement appropriate technical and organizational measures, so that the processing is in compliance with the requirements of this Regulation and ensures the protection of the rights of the data subject.
2. The processor shall not engage another processor without the prior written authorization, specific or general, of the controller. In the latter case, the processor shall inform the controller of any intended changes concerning the incorporation or replacement of other processors, thus giving the controller the opportunity to object to such changes.
3. The processing by the processor shall be governed by a contract or other legal act under Union or Member State law, which binds the processor to the controller and establishes the subject matter, duration, nature, and purpose of the processing, the type of personal data and categories of data subjects, and the obligations and rights of the controller. Such contract or legal act shall stipulate, in particular, that the processor:
 - a) shall process the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organization, unless required to do so by Union or Member State law applicable to the processor; in such a case, the processor shall inform the controller of that legal requirement before the processing, unless that law prohibits such information on important grounds of public interest;
 - b) shall ensure that persons authorized to process personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;
 - c) shall take all necessary measures in accordance with Article 32(...).
4. When a processor engages another processor to carry out specific processing activities on behalf of the controller, the same data protection obligations as set out in the contract or other legal act between the controller and the processor referred to in paragraph 3 shall be imposed on that other processor, by way of a contract or other legal act established under Union or Member State law, in particular the provision of sufficient guarantees to implement appropriate technical and organizational measures so that the processing is in compliance with the provisions of this Regulation. If that other processor fails to fulfill its data protection obligations, the initial processor shall remain fully liable to the controller for the performance of the obligations of the other processor. (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
23/45

These specific obligations may be supervised by the data protection authorities, without prejudice to

the oversight that may be carried out regarding compliance with the GDPR or the LOPDGDD by the data controller or the data processor.

III

Allegations to the proposed resolution

In response to the allegations presented by HM, it should be noted, in the order presented, the following:

ALLEGATIONS

HM indicates:

First. Regarding data encryption.

In the proposed resolution, this Agency states that "In response to the allegations, this Agency must signify that at the time the investigation proceedings were initiated, as well as at the time the present sanctioning procedure was initiated, HM had the minimum level of encryption corresponding to the operating system and the database." Although we understand the concern, we believe it is necessary to reiterate that the instructor implies that HM HOSPITALES considers that encryption in the cabinet is not sufficient, and that is why we planned for software DES encryption of SQL.

We wish to underline several crucial aspects that demonstrate our deep commitment to data security:

1. Sufficiency of Hardware Encryption: Contrary to what has been suggested, the hardware encryption implemented in our disk cabinet provided security equivalent to SQL DES encryption. The only limitation detected was that the database capacity was restricted to the available space in the cabinet, a limitation that does not compromise the effectiveness of the encryption itself.

2. Implementation of SQL TDE Encryption: The transition to software TDE encryption of SQL was a proactive measure to eliminate database size restrictions and not a response to a security deficiency. This change reflects HM HOSPITALES' continuous improvement policy in security practices.

At HM HOSPITALES, providing healthcare is our main activity. While data security is crucial, it is equally important to ensure the availability of this data for the continuous care of patients. Below, we detail how we have managed this balance:

1. Caring for our patients: Our process for implementing the new encryption has been planned with the aim of ensuring that patient care is not interrupted. This has sometimes involved postponing encryption updates to maintain continuous accessibility to the clinical data necessary for care.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/45

2. Inclusion of New Centers: The expansion of our network with the addition of six new hospitals brought significant challenges in terms of data integration and management of technological infrastructure. Despite these challenges, we ensured that encryption measures were implemented without compromising the integrity or security of the data.

3. Balance between security and accessibility: We understand that quick and secure access to medical data is vital for effective care. Therefore, our encryption solutions are designed to ensure both data protection and immediate accessibility when healthcare professionals require it.

This approach demonstrates our dedication to providing high-quality medical care, ensuring that data security measures support our primary mission and do not hinder patient care.

Finally, we want to reiterate that the encryption previously used by HM HOSPITALES already provided a level of security that exceeded the minimum indicated by the AEPD:

1. High Security: We used advanced encryption standards such as AES-128 and AES-256, ensuring that the data was protected against unauthorized access. These encryption methods are extremely robust and widely recognized for their effectiveness.

2. Firmware Level Encryption: By encrypting data at the firmware level (by LUN), we ensured that data protection was applied to the entire logical unit, providing an additional layer of security directly integrated into the hardware.

3. Self-Encrypting Drives (SED): The self-encrypting drives that used hardware encryption instead of

firmware offered significant advantages, such as:

3.1. Performance: There was no loss of performance as the encryption did not burden the system. This was crucial in environments that require high availability and consistent performance.

3.2. Enhanced Security: Hardware-level encryption is less susceptible to certain types of attacks that could affect software or firmware-based solutions.

3.3. Regulatory Compliance: The use of these levels of encryption helped HM HOSPITALES comply with various data protection and information security regulations.

The information provided by the manufacturer of the cabinet regarding the security of the encryption system used is included as a link for further clarification:

<https://www.fujitsu.com/global/products/computing/storage/disk/eternusdx/feature/strsys-d11.html>

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/45

An additional informative document regarding the technical characteristics guaranteed by the supplier Fujitsu, as well as a certificate from our supplier TRC INFORMATICA related to data encryption, is also attached as ANNEX I.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/45

In response to the allegations, this Spanish Agency for Data Protection must insist on the fact that the SQL Server database system that HM had has its own encryption system, a minimum level of encryption for the processing of personal data.

This minimum level of encryption meant that, in the event of a physical loss of control of the system, there would be difficulty in accessing it; however, in the event of unauthorized access to the system, there would be no barrier preventing access to the data and documents.

This encryption system served to reinforce and complete the encryption system configured by default on the server itself.

And this is acknowledged by the entity being claimed in its statement of allegations dated September 14, 2023, in which it expressly states:

“At the time of the allegations, the TDE system was in the implementation period – as of today it is already implemented – which comes to improve the one that existed at that time, the encryption system carried out by the ‘Controller Module’ of the storage cabinet. HM HOSPITALES only conveyed information in its 11 previous writings about the software improvement process from Hosma to Doctoris, and the new and additional encryption process that was being carried out with the aim of implementing encryption with TDE technology from SQL Server in the clinical records information system.

The model of the storage cabinet used by the clinical records information system DX200 S4 has and had automatic encryption in the disk storage systems using AES 128-bit technology or Fujitsu Original Encryption, ensuring that the data is protected when used and during data transfers to archiving facilities at another location...” (The underlining is from this agency).

It is evident that if there is an improvement over what already existed, it is because the implemented encryption system was insufficient; and all this, despite the fact that the type of data being processed required the best existing encryption system and the most suitable for the risk of processing such data on a large scale and special categories of personal data, among other issues, which could not be, as has been demonstrated, with a system established by default on the server itself. Its insufficiency in relation to the risks is what determines the commission of the infringement and the imposition of the sanction.

Consequently, it is evident that there is a lack of a personal data encryption system commensurate

with the estimated potential risks.

As stated in the sixth proven fact, HM HOSPITALES has been entering into contracts with the public sector for the provision of healthcare since the year 2022:

Therefore, from that moment on, HM HOSPITALES is obliged to comply with the National Security Scheme, in accordance with the provisions of Article 2 of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/45

Royal Decree 311/2022, of May 3, which regulates the National Security Scheme, establishes:

“Article 2. Scope of application.

1. This royal decree applies to the entire public sector, as defined by Article 2 of Law 40/2015, of October 1, and in accordance with the provisions of Article 156.2 of the same.
2. Likewise, without prejudice to the application of Law 9/1968, of April 5, on Official Secrets and other special regulations, this royal decree shall apply to systems that handle classified information, and it may be necessary to adopt complementary security measures specific to such systems, arising from the international commitments undertaken by Spain or from its membership in international organizations or forums.
3. This royal decree also applies to the information systems of private sector entities, including the obligation to have the security policy referred to in Article 12, when, in accordance with applicable regulations and by virtue of a contractual relationship, they provide services or solutions to public sector entities for the exercise of their administrative powers and competencies.”

Furthermore, we must emphasize what is stipulated in the 1st Additional Provision of the LOPDGDD, which establishes:

“First Additional Provision. Security measures in the public sector.

1. The National Security Scheme will include the measures that must be implemented in the event of processing personal data to prevent its loss, alteration, or unauthorized access, adapting the criteria for determining risk in the processing of data to what is established in Article 32 of Regulation (EU) 2016/679.
2. The responsible parties listed in Article 77.1 of this organic law must apply to the processing of personal data the corresponding security measures provided for in the National Security Scheme, as well as promote a degree of implementation of equivalent measures in companies or foundations linked to them subject to private law.

In cases where a third party provides a service under a concession, management assignment, or contract, the security measures will correspond to those of the originating public administration and will comply with the National Security Scheme.”

On the other hand, it should not be forgotten what is provided in Article 3 of the aforementioned Royal Decree 311/2022, which expressly states:

“Article 3. Information systems that process personal data.

1. When an information system processes personal data, the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and on the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation), and in Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, or, where applicable, Organic Law 7/2021, of May 26, on the protection of personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and the execution of criminal sanctions, the rest of the applicable regulations, as well as the criteria established by the Spanish Data Protection Agency or, within its jurisdiction, by the regional data protection authorities, shall apply, without prejudice to the requirements established in this royal decree.”

In relation to encryption, the National Security Scheme establishes:

5.7.3 Encryption of information [mp.info.3].

For the encryption of information, the following shall apply:

dimensions C low level medium high
does not apply does not apply applies

a) Information with a high level of confidentiality will be encrypted both during its storage and during its transmission. It will only be in clear text while it is being used.

[...]

Consequently, encryption must be applied to:

- a) The confidentiality dimension,
- b) Data at the high level, and
- c) Data stored (at rest).

Using proper encryption involves the following:

- That the encryption system used is not compromised, meaning that at the time of use, there is no known way to break it.
- That there is an adequate and robust key management system, as well as a procedure for managing cryptographic material in general.

When selecting an encryption method, in addition to considering the two previous points, it should be noted that the available options have different characteristics, so it will be necessary to analyze and choose the encryption system that best fits the service in which it is to be integrated, that is, whether it will be used for sending information to a third party, whether encryption at rest is required, etc.

That said, we must emphasize that the SQL Server database system that HM had its own encryption system, a minimum level of encryption for the processing of personal data.

Consequently, HM did not take care to assess and evaluate whether that encryption system was sufficient to guarantee an adequate level of security relative to the risk.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/45

This minimum level of encryption implied that, in the event of a loss of physical control of the system, there would be difficulty in access; however, in the case of unauthorized access to the system, there would be no barrier preventing access to the data and documents. This encryption system served to reinforce and complete the encryption system configured by default on the system's own server.

Consequently, it is evident that HM did not have a robust encryption system to ensure an adequate level of security against the risks involved in the processing of personal data. HM continues to state that

Second. Audits.

This party wishes to make the following considerations regarding the comments made by this Agency: "The performance of audits on the DOCTORIS information system (nor its previous versions) to ensure the implemented technical and organizational security measures has not been accredited."

In relation to the comments made by this Agency regarding the lack of accreditation of audits on the DOCTORIS information system (and its previous versions) to ensure the implemented technical and organizational security measures, this Party wishes to make the following considerations:

There may have been some misunderstanding throughout the Procedure, attributable in any case to our Party, as the opposite of the assertion made by this Agency, HM HOSPITALES has various channels to accredit the continuous review of its Privacy Management System. In previous submissions, documentary evidence was provided of the review by the DPO Department of the new acquisitions by the hospital group, in this case, the hospital centers in Málaga. This review materializes in audits referred to as compliance audits, where an initial compliance diagnosis (COMPLIES/DOES NOT COMPLY/NOT APPLICABLE) is made, taking into account Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation) and Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights.

These audits are primarily planned when there is a structural modification in a particular company

(transformation, absorption, merger, transfer, etc.) or when a business or activity is transferred, or if it ceases operations. In this regard, given the expansion of the hospital group, the preparation of this type of audit in the network of hospitals in the province of Málaga was planned, as has been evidenced in previous submissions.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

30/45

Different from these audits, HM HOSPITALES reviews from the design or as a consequence of compliance with Article 24.1 of the GDPR “Such measures will be reviewed and updated when necessary,” as we have stated in previous submissions and which we understand should be provided for greater clarity in these:

1. External Audit Report on Compliance with the Procedure for the Standardization of the Electronic Private Prescription System.

Due to the certification of the prescription systems and repositories of the private electronic prescription system, a thorough audit was conducted on the DOCTORIS software certifying its compliance with the required standards for safe and reliable operation within the scope of private electronic prescriptions. We provide as Annex No. II the complete report demonstrating the rigor with which the security and compliance of the software subject to sanction is evaluated.

2. KPMG Audit Report.

Annually, HM HOSPITALES is externally audited by KPMG, a renowned international auditing firm. In these audits, the DOCTORIS software is reviewed, among other issues. Given the confidential nature of the full content of the report, direct access to all the information was not possible; however, for clarification of this section, we consider it appropriate to provide in the same Annex No. II the results of KPMG for the year 2023.

The presentation emphasizes that DOCTORIS meets specific security criteria and confirms that data protection measures are adequately implemented and effective.

In response to the allegations, this Agency merely reminded HM that Article 32 of the GDPR establishes the need for “verification and evaluation” of the technical measures implemented by the controller:

Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which in particular includes, among others:

(...) d) a process for regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

Therefore, it is evident that this is a principle that establishes for the controllers and processors the “proactive” obligation to comply with the regulation and this through the implementation of appropriate technical and organizational security measures. Such measures must also be reviewed and updated periodically.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

31/45

It is the entity itself that states that “... in the last three years, no specific audit has been conducted on the software...” justifying the absence of these audits by the fact that DOCTORIS is in constant change/improvement, without those changes or improvements being documented.

However, HM states, and this is recorded in the file, that “once the health emergency situation was overcome, the HM HOSPITALES Privacy Committee approved in April 2023 the conduct of audits in

various centers to verify the level of compliance with the current regulations for the protection of all information systems in the second half of this year...".

It is noted that the report provided by HM during the evidentiary period corresponds to the Results Report of the Audit carried out only in the centers located in Málaga, as a consequence of its incorporation into the group in 2022. It is surprising that, at this point in the proceedings, HM provides; despite what has been stated, a report dated January 2021, which expressly states:

Therefore, it is noted that this audit only pertains to the Private Electronic Prescription System used by HM Hospitales and not "DOCTORIS" as the hospital management software used by HM HOSPITALES 1989, S.A.

However, in the December 2023 report from KPMG presented and referenced by the responding entity in its allegations, there is a brief mention of IT improvement areas regarding the software "DOCTORIS".

It is important to highlight and record in this resolution that this report expressly contains:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/45

Evidently, this audit does not fulfill the obligation of the data controller to verify, evaluate, and assess the effectiveness of the technical and organizational measures implemented, in this case, in the hospital management software used by HM HOSPITALES 1989, S.A. "DOCTORIS" to ensure the security of the processing.

Regarding the IT improvement areas concerning the software "DOCTORIS", it should be mentioned that, in any case, it refers to improvements in the software environment and not improvements of the software itself with the aim of ensuring appropriate technical and organizational measures to guarantee an adequate level of security in relation to the risk of personal data processing carried out by the aforementioned software.

HM continues to state that:

Third. Guarantee of compliance by the Data Processor.

In reference to the selection of the provider of the Clinical History management system, TRC INFORMATICA, S.L., we would like to inform that this provider complies with the stipulations of Article 28.1 of the GDPR, which states the following: "When processing is to be carried out on behalf of a data controller, the controller shall choose only a processor that provides sufficient guarantees to implement appropriate technical and organizational measures, so that the processing will be in compliance with the requirements of this Regulation and will guarantee the protection of the rights of the data subject." In line with this statement, Article 28.5 of the GDPR indicates that the adherence of the data processor to an approved code of conduct...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/45

the provisions of Article 40 or an approved certification mechanism under Article 42 may be used as evidence to demonstrate the existence of the sufficient guarantees referred to in paragraphs 1 and 4 of this article."

Thus, TRC INFORMATICA, S.L. provides as ANNEX No. III the certifications currently granted to it, which demonstrate not only the commitment and regulatory compliance by the provider TRC INFORMATICA, S.L., but also the diligence of HM HOSPITALES in selecting the Data Processor, ensuring that all appropriate technical and organizational measures are implemented to guarantee the protection of the rights of the data subjects.

The following Certificates are included in the referenced Annex:

- Certificate from OCA-Instituto de Certificación, SLU for the environmental management system of

TRC in accordance with the UNE-EN ISO 14001:2015 standard.

- Certificate from OCA-Instituto de Certificación, SLU for the IT service management system in accordance with the ISO/IEC 20000-1:2018 standard.
- Certificate from OCA-Instituto de Certificación, SLU for the information security management system of TRC in accordance with the UNE-ISO/IEC 27001:2017 standard.
- Certificate from OCA-Instituto de Certificación, SLU for the occupational health and safety management system of TRC in accordance with the UNE-EN ISO 45001:2018 standard.
- Certificate from OCA-Instituto de Certificación, SLU for the quality management system of TRC in accordance with the UNE-EN ISO 9001:2015 standard.
- Certificate from OCA-Instituto de Certificación, SLU for the software maturity of TRC in accordance with the ISO/IEC 15504 standard.
- Certificate from OCA-Instituto de Certificación, SLU for the information technology of TRC in accordance with the ISO/IEC 33001:2015 standard.
- Certificate from IMQ IBÉRICA in compliance with the National Security Scheme High Level.
- Certificate from OCA-Instituto de Certificación, SLU in compliance with the National Security Scheme Medium Level. Renewed for High Level.

In response to the allegations, we must mention that this Spanish Agency for Data Protection has never questioned the diligence of HM HOSPITALES in selecting the Data Processor nor the commitment or regulatory compliance by the provider and Data Processor TRC INFORMATICA, S.L. However, this Spanish Agency for Data Protection acknowledges the certifications granted to TRC INFORMATICA, S.L.

The entity alleges that:

Fourth. Regarding the demonstration during the procedure of compliance with Article 32 of the General Data Protection Regulation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/45

HM HOSPITALES has shown a firm commitment to complying with the security measures and protection of personal data, maintaining and improving the measures already implemented.

The AEPD bases the investigation and establishes an initial proposed sanction of 200,000 euros for the non-compliance with several control points, the degree of compliance (in whole or in part) of which has been demonstrated with the documentation provided in the various submissions to the AEPD as detailed below:

I. Regarding the lack of measures to ensure the confidentiality of the data, this Agency should validate that the encryption previously used by HM HOSPITALES provided a level of security that exceeded the minimum indicated by the AEPD (hardware encryption implemented in our disk cabinet provided security equivalent to SQL DES encryption), and that it has been improved with the implementation of an encryption system using SQL Server TDE technology.

In response to the allegations, this agency must insist on the fact that if HM has improved the encryption system, it is because that system was insufficient and inadequate to the level of risk in data processing, as proven.

II. Regarding the possible use of real databases used for testing in pre-production and development systems, it was demonstrated and sufficiently accredited that fictitious data is used in testing environments.

In response to this point, we must state that nothing has been alleged by this Spanish Agency regarding the use of real databases for testing in pre-production and development systems. However, we celebrate that fictitious data is used in testing environments.

III. In relation to the possible lack of traceability of access to the hospital management system by users who consult patient medical records, a document prepared by TRC was provided and is reproduced here, demonstrating with screenshots from the DOCTORIS program the traceability of users accessing

patient medical record data.

In response to the allegations regarding traceability, this Spanish Agency for Data Protection already pointed out in the proposed resolution that it welcomed the fact that HM HOSPITALES had rectified the deficiencies detected during the processing of this sanctioning procedure regarding traceability. However, it is true, as stated in the tenth proven fact, in the Compliance Report accompanying the Data Protection Impact Assessment Report HM HOSPITALES 1989, S.A., dated March 15, 2023, and under the responsibility of Mr. [Name], Data Protection Officer, it literally states:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/45

On the other hand, the rectification of these deficiencies made clear the insufficiency and weakness of the technical and organizational security measures implemented to ensure the traceability of access to personal data by authorized users, and, therefore, the commission of the infringement. In this regard, the ruling of the National Court (AN) dated February 9, 2023 (rec. 770/2022) was noted, which states:

“(…) The security measures implemented subsequently do not affect the commission of the infringement and, contrary to what the plaintiff intended, cannot justify the application of an exemption, without prejudice to being taken into consideration as a mitigating factor under Article 83.2.c) of the GDPR when determining the sanction.”

IV. Regarding the conduct of audits on any of the versions of DOCTORIS, a complete report of the audit carried out for the certification of the electronic prescription is provided, along with the report prepared by KPMG. In response to the allegations regarding the conduct of audits, this agency must emphasize that the report prepared by KPMG pertains solely to the Private Electronic Prescription System used by HM Hospitales and not “DOCTORIS” as the hospital management software used by HM HOSPITALES 1989, S.A.

V. Regarding user profiles, we inform this Agency of our strong commitment to the constant improvement of this aspect, considering, moreover, that we are a hospital group that is in constant expansion. We would like to remind this Agency that in the KPMG Audit provided as an observation during the year 2023, it has been observed that the Group has reduced the number of profiles (there were more than 400 and now there are about 50). Similarly, it should be noted that a Commission for the review of profiles and permissions has been created, which has been analyzing, reducing, and homogenizing the permissions assigned in DOCTORIS. This commission will remain in place to make decisions about new accesses that fall outside the usual circuit of defined profile assignments. This follow-up should only be valued as a diligent and proactive attitude and not negligent.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
36/45

In response to the allegations, this Spanish Agency for Data Protection congratulates the measures adopted to avoid poorly implemented profiles and permissions; however, we must insist on what is stated in the ruling of the AN dated February 9, 2023 (rec. 770/2022), which says:

“(…) The security measures implemented subsequently do not affect the commission of the infringement (…).”

Finally, before addressing the other allegations, this Agency must highlight the assumption of responsibility by HM regarding the error in the implementation of the profiles, as well as the absence of an automatic deletion and blocking system. HM continues to state that:

In response to the interpretation of the jurisprudence of the Supreme Court provided by the AEPD, “The Supreme Court (Rulings of April 16 and 22, 1991) considers that from the culpability element it follows that ‘...the action or omission, classified as an administratively sanctionable infringement, must be, in any case, attributable to its author, either by intent or negligence, imprudence, or excusable ignorance.’ The same Court reasons that ‘it is not enough... for exculpation against a typically unlawful behavior to invoke the absence of fault’ but it is necessary ‘that the diligence required by the one claiming its non-existence has been employed’ (STS January 23, 1998).”

HM HOSPITALES wishes to emphasize that the improvements in security systems implemented are not a consequence of this sanctioning procedure. These improvements were already identified and programmed as part of our continuous improvement plan before the initiation of the procedure, demonstrating a proactive and constant commitment to data security. Highlighting the diligence of HM HOSPITALES, as evidenced in the certification processes under the National Security Scheme and ISO 27001, recognized in previous allegations. These certification processes are proof that the required diligence has been employed to ensure the security and protection of our patients' personal data.

Furthermore, at HM HOSPITALES, as previously indicated, the availability of data for healthcare is a priority that is managed without compromising security. The measures implemented ensure both the protection of data and its accessibility, allowing for the provision of quality service to patients.

In conclusion, the aforementioned compliance should lead to a reduction or graduation in the amount of the sanction, as it has been demonstrated that HM HOSPITALES has acted with due diligence, anticipating and proactively addressing security needs within a framework of continuous improvement and not as a response to legal or administrative actions.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/45

First of all, and before addressing the allegations, it is essential to agree that there can be no economic sanction if there is no concurrence of intent or negligence in the infringement.

To this end, it is necessary to refer to the invoked Judgment of the Court of Justice of the European Union, dated December 5, 2023, in case C-807/21 (Deutsche Wohnen), which states:

“76 In this regard, it should also be specified, concerning the question of whether an infringement has been committed intentionally or negligently and, therefore, can be sanctioned with an administrative fine under Article 83 of the GDPR, that a data controller may be sanctioned for behavior falling within the scope of the GDPR when they could not ignore the infringing nature of their conduct, whether or not they were aware of infringing the provisions of the GDPR (see, by analogy, the judgments of June 18, 2013, Schenker & Co. and others, C 681/11, EU:C:2013:404, paragraph 37 and cited case law; of March 25, 2021, Lundbeck/Commission, C 591/16 P, EU:C:2021:243, paragraph 156, and of March 25, 2021, Arrow Group and Arrow Generics/Commission, C 601/16 P, EU:C:2021:244, paragraph 97).” (the underlining is ours).

In the same vein, the courts of our country express themselves. Thus, the Judgment of the National Court, dated January 21, 2010, states:

“The appellant also maintains that there is no culpability in their actions. It is true that the principle of culpability prevents the admission of objective responsibility in administrative sanctioning law; it is also true that the absence of intent is secondary since this type of infringement is usually committed through culpable or negligent conduct, which is sufficient to integrate the subjective element of fault. The conduct of XXX is clearly negligent since... they must know... the obligations imposed by the LOPD on all those who handle personal data of third parties. XXX is obliged to guarantee the fundamental right to the protection of personal data of their clients and potential clients with the intensity required by the content of the right itself.”

Furthermore, the Supreme Court (Judgments of April 16 and 22, 1991) considers that from the

culpability element it follows that “...the action or omission, qualified as a administratively sanctionable infringement, must be, in any case, attributable to its author, by intent or negligence, imprudence or inexcusable ignorance.” The same Court reasons that “it is not enough... for exculpation against typically unlawful behavior to invoke the absence of fault” but it is necessary “that the diligence required by the one claiming its non-existence has been employed” (STS January 23, 1998). Also connected with the degree of diligence that the data controller is obliged to exercise in compliance with the obligations imposed by data protection regulations is the Judgment of the National Court of October 17, 2007 (Rec. 63/2006), which specified: “(...) the Supreme Court has understood that there is imprudence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/45

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or failure to comply with the duties imposed by the Law on those responsible for files or data processing to exercise due diligence is sufficient...” (Judgment of the National Court of June 29, 2001).

Consequently, it is evident that in the present case there is negligence due to this lack of diligence in complying with the current regulations on data protection, and therefore, a reduction or gradation in the amount of the sanction is not warranted.

HM continues by stating that:

Fifth. On the principle of proportionality in the imposition of sanctions.

The principle of proportionality, as established in Article 29 of Law 40/2015 on the Public Sector Regime, is fundamental in the imposition of sanctions by Public Administrations. This principle indicates that:

- 29.2: The establishment of monetary sanctions must ensure that the commission of the classified infringements does not result in a greater benefit for the infringer than compliance with the violated norms.
- 29.3: The determination of the sanctioning regime and the imposition of sanctions must observe the suitability and necessity of the sanction to be imposed, adapting it to the severity of the infringement. The gradation of the sanction must particularly consider the following criteria:
 - Degree of culpability or intent: Assess whether there was a deliberate intention to violate the regulations.
 - Continuity or persistence in the infringing conduct: Determine whether the infringing conduct has been continuous or persistent.
 - Nature of the damages caused: Consider the damages or injuries caused by the infringement.
 - Recidivism: Take into account whether there has been recidivism due to the commission of more than one infringement of the same nature within a year, declared by a firm resolution in the administrative process.

In the present case, HM HOSPITALES has demonstrated the absence of a deliberate intention to violate the regulations (Article 32 of the General Data Protection Regulation) and the absence of “continuity or persistence in the infringing conduct,” facts that can be evidenced by the detailed compliance and the additional implementation of mechanisms and reinforcements in the already existing security measures to ensure greater protection of personal data, which, combined with its diligence and good faith, should be a determining factor in the assessment of the proportionality of the sanction.

Likewise, regarding the “nature of the damages caused,” there has been no claim or impact on the fundamental rights of the users, nor have we had breaches or security incidents that...

C/ Jorge Juan, 6
www.aepd.es

affect or endanger the data, nor has any damage or harm been caused by the infringement. Regarding "recidivism," this is the first time a breach has occurred in the area subject to complaint (security measures in DOCTORIS), and there is no aggravating factor of recidivism applicable to this type of conduct, making it necessary to reconsider the severity of any sanction imposed under these principles.

In response to the allegations, it should be noted, first of all, that Article 29 of Law 40/2015 on the Public Sector Regime (hereinafter, LRJSP) does not apply to the sanctioning regime imposed by the GDPR, given that the GDPR itself has its own proportionality regime in Article 83 of the GDPR. Specifically regarding the sanctioning regime provided for in the GDPR, its provisions apply immediately, directly, and integrally, foreseeing a complete system that must be understood, interpreted, and integrated in a complete and integral manner, thus preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. Thus, regarding the imposition of fines under the terms of Article 83 of the GDPR, these must be effective, proportionate, and dissuasive for the achievement of the intended purpose of the GDPR. For this system to function with all its guarantees, it is necessary for several elements to be deployed in a complete and integral manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR—or in the LOPDGDD in the Spanish case—would undermine the effectiveness of the system, which would lose its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, the interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms, resulting in the absence of any legal gap that determines the applicability of Article 29 of Law 40/2015. Furthermore, it should be indicated that Article 63.2 of the LOPDGDD not only establishes the supplementary nature (which would serve to fill gaps that do not exist, as we have seen) but also the subsidiary nature (which is not supplementary) of the general regulations of administrative procedures concerning the rules governing the procedures of the AEPD in matters of data protection.

Article 63.2 of the LOPDGDD states:

“2. The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not...”

they contradict, in a subsidiary manner, the general rules on administrative procedures...”.

The Spanish legislator has thus opted for the principle of subsidiarity, not of suppleness, of the general rules of administrative procedure over the specific ones of the GDPR and LOPDGDD. This relationship between suppleness and subsidiarity must be understood, as the Chamber to which we are addressing has already done, in the sense mentioned in the ruling of the National Court of October 23, 2001 (Rec. 390/1999, ECLI:ES:AN:2001:6122), when it recalled that “the recourse to subsidiarity is a formula of normative collaboration for cases of concurrence of norms, that is, for cases in which two or more of them are applicable to the same factual situation, so that the subsidiary yields in favor of the primary one which, in its case, complements,” unlike suppleness, which aims to fill a gap “in such a way that when a certain situation is not subject to regulation by the initially applicable norm, the supplementary one is applied, always provided that such an operation does not, for other

circumstances, conflict with the legal system.”

In the present case, the primary norm would be the GDPR, which expressly regulates in its Article 83 the principle of proportionality, with the regulation of Article 29 of Law 40/2015 not being applicable precisely due to its subsidiary nature.

Secondly, it should be noted that Article 83.4 of the GDPR states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

Therefore, a fine of:

- 200,000 euros, in the case of the violation of Article 32 of the GDPR,

is found in the lower range of possible sanctions, thus complying with the aforementioned Article 83.1 of the GDPR: “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this article for the violations of this Regulation indicated in paragraphs 4, 5, and 6 are in each individual case effective, proportionate, and dissuasive.”

However, this Agency must record that, in the graduation of the sanction and given the specialty of the matter, the following criteria have been taken into account by imperative of Article 83.2 of the GDPR and paragraph 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/45

As aggravating factors:

-

b) the intentionality or negligence in the violation;

We insist in this regard on what has already been argued regarding the intentionality or negligence in the violation.

As aggravating factors:

-

b) The link of the infringer's activity with the processing of personal data.

The link between the business activity and the processing of patients' personal data is evident, also indicating that such processing was carried out on a large scale, as stated in the fifth proven fact.

IV

Article 32 of the GDPR

Article 32 “Security of processing” of the GDPR establishes:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or

the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/45

instructions of the controller, unless required to do so under Union or Member State law.”

In this case, it is established that HM did not have reasonable security measures in place according to the estimated potential risks.

Regarding the adequacy of the measures implemented to those required for systems processing health data and medical records:

It has been confirmed that the DOCTORIS system (and its previous versions) DOES perform traceability of which users have accessed the information system and whether these accesses were correct or failed; it also records traceability on which modules of the system each user has visited (menu options used). However, the following deficiencies have been evidenced:

(...).

There are internal reports from the controller HM regarding compliance with regulations for these activities that include the following conclusions:

(...).

The performance of audits on the DOCTORIS information system (nor its previous versions) to ensure the implemented technical and organizational security measures has not been evidenced.

HM states that “Regarding the performance of audits on any of the versions of Doctoris in the last three years, this party informs that none have taken place.” This lack contrasts with the following statement made in the Record of Processing Activities in the section regarding the security measures of the HCE activity:

Performance of audits on the implemented technical and organizational security measures to verify their proper functioning.

Regarding the guarantee of confidentiality in the processing, it has been established that (...).

However, concerning the measures to ensure the deletion or blocking of data: (...).

Based on the above, it is considered that the known facts constitute an infringement attributable to HM for violation of Article 32 of the GDPR.

V

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringement classified in Article 83.4 a) of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/45

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...).”

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, those infringements that constitute a substantial violation of the articles mentioned therein are considered serious and shall prescribe after two years, particularly the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

VI

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- b) the intent or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be emphasized the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]

It is also considered appropriate to graduate the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/45

As aggravating factors:

-

b) The connection of the infringer's activity with the processing of personal data.

HM provides healthcare services for the care and well-being of our patients and their families through a comprehensive care offering, with the commitment to add value to clients, shareholders, employees, and society as a whole.

Its main activity is the management of healthcare services, teaching, and research for the maintenance and improvement of the health of the population, which requires continuous knowledge and processing of special categories of personal data of its patients and users.

Such processing, as stated in the Data Protection Impact Assessment Necessity Analysis Report provided by HM HOSPITALES on September 14, 2023, is on a large scale.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for an initial penalty of €200,000 (TWO HUNDRED THOUSAND EUROS).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on HM HOSPITALES 1989, S.A., with NIF A79325858, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of €200,000.00 (TWO HUNDRED THOUSAND euros).

SECOND: TO NOTIFY this resolution to HM HOSPITALES 1989, S.A.

THIRD: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that they must pay the imposed penalty once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, in the restricted account No. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the period for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment period will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/45